

RETO 4 · DESARROLLO EN PLATAFORMAS V

PCiberseguridadIC

Plataforma de gestión de incidentes de ciberseguridad

Estudiante: Jefferson Ismael Condo Cepeda

El problema y el usuario

Analista

Registra incidentes y los prioriza.

Supervisor

Revisa y actualiza el seguimiento.

Administrador

Gestiona usuarios y auditoría.

Sin persistencia ni permisos, el historial se pierde y cualquiera puede alterarlo.

Arquitectura cliente-servidor en capas

Navegador

React + Vite, sitio estático en Render

API Express 5

Middlewares, controladores y servicios

Prisma

Modelos y migraciones versionadas

PostgreSQL

Base administrada

Configuración por entorno · health check /health · logs estructurados

Demostración del flujo

1. HTTPS e inicio de sesión fallido
2. Login como Administrador
3. Crear, filtrar y editar un incidente
4. La validación rechaza datos inválidos
5. Eliminación lógica y recarga: los datos persisten
6. Analista: 403 al intentar eliminar

Ciberseguridad aplicada

Control	Riesgos que reduce
Contraseñas con bcrypt	Robo de credenciales desde la base
JWT en cookie HttpOnly, 2 horas	Robo de sesión por XSS
Token CSRF y CORS por origen exacto	Peticiones desde sitios ajenos
Roles validados en el servidor (401 y 403)	Acceso y acciones indebidas
Zod y límite de 10 KB por solicitud	Inyección y datos malformados
Límite de login: 429 al exceder	Fuerza bruta
Helmet y logs sin secretos	Clickjacking y fuga de información

Seguridad en internet: defensa en profundidad

- Todo el tráfico por HTTPS; la cookie de sesión solo viaja cifrada
- Secretos solo en variables del proveedor; JWT_SECRET de 32 o más caracteres
- CORS limitado al origen exacto del frontend
- Lint, Jest y npm audit antes de cada despliegue
- Monitoreo con /health y logs sin datos sensibles
- Plan de reversión: volver al último despliegue estable

Ningún sistema es invulnerable: se reduce el riesgo en capas y se declaran los límites.

Pruebas, calidad y despliegue

7 de 7

pruebas Jest de reglas de negocio

28 → 0

errores de ESLint

21,95 → 7,62 ms

consulta a /api/incidentes

Render: build con migraciones · health check /health · logs del proveedor

Limitaciones y lecciones

Limitaciones

- Tokens revocados y caché en memoria: escalar requiere Redis
- Plan gratuito con arranque lento
- Faltan 2FA, alertas y respaldos probados

Lecciones

- La seguridad también se juega en el cliente
- Probar de verdad antes de cada despliegue

Gracias · quedo atento a sus preguntas